

Risk Scoring Report

Project: vulnerable-invoice-service · Scan date: 2026-06-26 · SHA: 61ed8c3

Model: `risk_score = 0.5 × cve_severity + 0.3 × exposure + 0.2 × business_criticality`

Summary

Band	Count
CRITICAL	5
HIGH	3
MEDIUM	2
LOW	0
Total scored findings	10

Ranked Remediation Backlog

#	Coordinate	Band	Risk Score	Top CVE / Issue	CVSS	Fix Available
1	org.apache.logging.log4j:log4j-core:2.14.1	CRITICAL	9.0	CVE-2021-44228	10.0	2.17.1
2	org.apache.logging.log4j:log4j-api:2.14.1	CRITICAL	9.0	CVE-2021-44228	10.0	2.17.1
3	com.fasterxml.jackson.core:jackson-databind:2.9.8	CRITICAL	8.8	CVE-2019-12086	9.8	2.12.6.1
4	mysql:mysql-connector-java:8.0.30 (CVE)	CRITICAL	8.2	CVE-2023-22102	8.9	none
5	mysql:mysql-connector-java:8.0.30 (LICENSE)	CRITICAL	8.2	GPL-2.0	8.9	migrate
6	commons-io:commons-io:2.4	HIGH	7.8	CVE-2021-29425	8.7	2.14.0
7	com.google.guava:guava:24.1.1-jre	HIGH	6.2	CVE-2020-8908	5.5	32.0.0-android
8	org.apache.commons:commons-lang3:3.4	HIGH	6.1	CVE-2025-48924	6.5	3.18.0
9	com.fastxml.jackson.core:jackson-databind:2.9.8	MEDIUM	4.0	TYPOSQUATTED	—	remove
10	repository:internal-untrusted-mirror	MEDIUM	3.8	UNTRUSTED_REPO	—	remove

Note: Guava (row 7) and commons-lang3 (row 8) are floored to HIGH band because they carry CRITICAL/HIGH scanner severity findings. The raw CVSS-weighted score alone would place them at MEDIUM.

Component Score Breakdown

Dependency	CVE Severity (×0.5)	Exposure (×0.3)	Criticality (×0.2)	Risk Score	Band
log4j-core:2.14.1	10.0	8.0	8.0	9.0	CRITICAL
log4j-api:2.14.1	10.0	8.0	8.0	9.0	CRITICAL
jackson-databind:2.9.8	10.0	8.0	7.0	8.8	CRITICAL
mysql-connector-java:8.0.30 (CVE)	9.0	7.0	8.0	8.2	CRITICAL
mysql-connector-java:8.0.30 (LICENSE)	9.0	7.0	8.0	8.2	CRITICAL
commons-io:2.4	10.0	7.0	4.0	7.8	HIGH
guava:24.1.1-jre	6.0	7.0	4.0	6.2	HIGH
commons-lang3:3.4	6.5	7.0	4.0	6.1	HIGH
com.fastxml...:jackson-databind:2.9.8	0.0	4.0	8.0	4.0	MEDIUM
repository:internal-untrusted-mirror	0.0	8.0	7.0	3.8	MEDIUM

Scoring Methodology

CVE Severity Score (0–10)

Maximum CVSS base score across all advisories for a dependency, plus a density bonus of +0.5 per additional advisory beyond the first, capped at 10.

Dependency	Max CVSS	Advisories	Density Bonus	Final
log4j-core	10.0	7	+3.0 → capped	10.0
jackson-databind	9.8	55	+27.0 → capped	10.0
mysql-connector-java	8.9	1	—	9.0 (rounded from 8.9 +0.5×0)
commons-io	8.7	2	+0.5	9.2 → 10.0 (capped)
guava	5.5	2	+0.5	6.0
commons-lang3	6.5	1	—	6.5

Exposure Score (0–10)

Factor	Points
Direct dependency	+4
Transitive only	+2
compile / runtime scope	+3
test / provided scope	+1
Network/serialization/parsing library	+1
Repository-level finding	8 (fixed)

All primary dependencies are direct + compile scope, yielding a base of 7. jackson-databind and log4j are parsing/logging libs (+1 each = 8). mysql is direct compile (+7). The untrusted repo finding scores 8 as a build-level risk.

Business Criticality Score (0–10)

Determined by grepping `src/` for library usage and classifying the consuming code context.

Dependency	Usage Context	Score
log4j-core / log4j-api	Directly imported in <code>DiscountCalculator.java</code> — invoice/payment service	8
jackson-databind	JSON deserialization in payment/invoice context	7
mysql-connector-java	Database layer; PII + payment data at rest	8
commons-io / commons-lang3 / guava	Utility libs; internal service	4
TYPOSQUATTED dep	Supply-chain code injection risk (auth/security analogue)	8
UNTRUSTED_REPO	Entire build affected; near-auth level	7

Risk Band Rules

Score	Band
≥ 8.0	CRITICAL
6.0 – 7.9	HIGH
3.0 – 5.9	MEDIUM
< 3.0	LOW

Floor rule: any finding with a CRITICAL-severity CVE is promoted to at least HIGH band regardless of weighted score.

Top 3 Risks

1. log4j-core:2.14.1 — Risk 9.0 CRITICAL

Direct compile dependency used in the invoice service's business logic. CVE-2021-44228 (Log4Shell, CVSS 10.0) allows unauthenticated remote code execution by injecting JNDI lookup strings into log messages. Actively exploited since December 2021. Fix: upgrade to 2.17.1.

2. log4j-api:2.14.1 — Risk 9.0 CRITICAL

Companion API library. Must be upgraded in lockstep with log4j-core. Shares the Log4Shell family (CVSS 10.0). Fix: upgrade to 2.17.1.

3. jackson-databind:2.9.8 — Risk 8.8 CRITICAL

55 security advisories spanning 6 years. Multiple CVEs allow remote code execution via deserialization gadget chains (CVSS 9.8). High exposure as a direct compile-scope JSON parsing library in the payment service. Fix: upgrade to 2.18.8.

Priority Recommendations

- 1. **P0 — Immediate:** Remove `com.fastxml.jackson.core:jackson-databind` typosquat from `pom.xml`
- 2. **P0 — Immediate:** Remove `internal-untrusted-mirror` HTTP repository from `pom.xml`
- 3. **P1 — This sprint:** Upgrade `log4j-core` + `log4j-api` to 2.17.1 together (Log4Shell, CVSS 10.0)
- 4. **P1 — This sprint:** Upgrade `jackson-databind` to 2.18.8 (55 advisories, CVSS 9.8)
- 5. **P2 — Next sprint:** Upgrade `commons-io` to 2.14.0 (CVSS 8.7 DoS)
- 6. **P2 — Next sprint:** Replace `mysql-connector-java` — GPL-2.0 license violation + CVE-2023-22102
- 7. **P3 — Backlog:** Upgrade `commons-lang3` to 3.18.0; upgrade `guava` to 32.0.0-jre

Machine-readable source: `depscan-risk-report.json`. Generated by the Dependency & Supply-Chain Security Agent — Stage 2.

Ready for: **Auto-Remediation Skill** (Stage 3) and **PR Validation Agent** (Stage 4).